06/01/2013
Revised 02/19/2026

OPR: WVOT Cybersecurity

COMPLIANCE WITH THIS PUBLICATION IS MANDATORY

Publications are available online at
https://sites.google.com/wv.gov/othub/policy-governance/ot-policies

Questions and change recommendations related to this publication shall be directed to this publication's Office of Primary Responsibility (OPR). This policy shall be reviewed annually to ensure continued alignment with current legal, operational, and strategic requirements. Revisions will be undertaken as necessary.

SUMMARY OF VERSIONS AND CHANGES

Version	Date	Revision Description
1	01/30/2015	Added Appendices A and B, Reorganized Phase 1 and 2
2	07/01/2015	Added Log History, Definitions, Reorganized Documents/Materials
3	09/01/2016	Reviewed - No Changes
4	10/20/2017	Reviewed - No Changes
5	12/31/2023	Updated website information in para. 4.0
6	02/19/2026	Changed name from Certification and Authorization Policy to Assessment and Authorization Policy, reformatted and made minor administrative updates.

1. PURPOSE

1.1. This policy establishes expectations to ensure that the West Virginia Office of Technology (WVOT) validates the security readiness for devices, systems, application and system software, and other technology prior to deployment into a production status. This validation includes appropriate reviews and/or testing of configurations, hardening, functionality and compliance with specifications, regulations, standards and those objectives that were the basis for the initiative.

2. SCOPE

2.1. This policy applies to all departments (including agencies, boards, authorities, and commissions) within the Executive Branch of WV State Government, excluding constitutional officers, the WV Board of Education, the WV Department of Education, and the county boards of education that have access to or use State-provided resources.

2.2. Where there are policies in place which provide less restrictions or security than this policy, those policies will be superseded by this policy. In instances where existing state and federal laws, regulations, and policies are more restrictive than this policy, the more restrictive provisions will prevail.

2.3. Applicable to all technologies deployed, and all employees who are responsible for these deployments, within the scope of responsibility of the WVOT.

3. POLICY

3.1. This policy provides the framework for control activities needed during the development, building, testing, and implementation of devices, systems, application and system software, and other technology within West Virginia State Government.

3.2. Assessment and Authorization (A&A) requirements must be part of the life cycle for all devices, systems, application and system software, and other technology, unless excluded in writing by the CIO.

3.3. The A&A Process should be initiated before deployment, and where possible, before acquisition of the system.

3.4. Whenever information systems contain Federal Tax Information (FTI), or other sensitive information as defined by the WVOT Data Classification Policy, the agency must:

3.4.1. Manage the information system using a life cycle methodology that includes information security considerations.

3.4.2. Obtain, protect as required, and make available to authorized personnel, adequate documentation for the information system.

3.5. The four phases of the A&A process include: Initiation, Assessment, Authorization, and Monitoring.

3.6. Phase I: Initiation and Research

3.6.1. The initiation phase should be the first step in the A&A process. This phase helps organize and gather all relevant information in a manner that will allow agency decision-makers to thoroughly and accurately evaluate all risk associated with the system in question.

3.6.2. The information gathered in this phase will vary between systems and devices, however most of the following information should be present in this stage of the A&A plan:

3.6.2.1. **System Information:** The intent of the development or deployment of the system at a high level. Information about the system should include what it is; where it is supposed to be installed; vendor or product information; technical specifications or any other information that would need to be known to do proper research on the system.

3.6.2.2. **System Requirements:** Categorizes any confidentiality, integrity and availability requirements; identification of known threats and/or vulnerabilities; and identifying initial risks (development and deployment), and ongoing risks (loss or compromise). Deployment owners must prepare appropriate materials and identify essential activities required to get devices, systems, application and system software, and other technology accredited for certification. Makes note of all security requirements.

3.6.2.3. **System Justification:** Program and systems managers must define and document business needs and requirements. This information is included in RFQs or RFPs.

3.6.2.4. **Responsible Parties:** Responsibilities for A&A must be assigned to the appropriate individual(s), and organizations will need to determine and define methods for implementing security requirements among identified stakeholders. This section identifies the stakeholders and the deployment (team) leader, including initiative sponsors. The Assessment and Authorization Teams should be identified in this phase.

3.6.2.4.1. **Assessment Team** – Should be staffed from the agency's internal security team, WVOT's Information Security Office, or a combination of both.

3.6.2.4.2. **Authorization Team** – Should be comprised of members from WVOT and the agency ultimately responsible for the system. The Authorization Team should be formed by individuals that have the authority to modify the project timeline and priorities, if needed.

3.6.2.5. **Time Frame:** Identifies the timeframe of the project or initiative (much of this could come from the project initiation documentation or charter),

3.6.2.6. **Known Issues or Concerns:** Records all stakeholder agreement(s), or concerns(s), on the Authorization plan and assessment criteria, and security requirements documentation.

3.7. All materials and information from Phase I should be passed on to the Assessment Team for Phase II.

3.8. Assessment: Phase II

3.8.1. The Assessment Team will identify the security best-practices for the system, based on NIST guidelines or other industry standards.

3.8.2. The Assessment team will create a security test and evaluation plan that includes:

3.8.2.1. Vulnerability testing and results.

3.8.2.2. Proposed risk and vulnerability assessment documentation; and

3.8.2.3. Proposed security Assessment and Authorization statements, addressing internal and external connections affecting the application or system, as needed.

3.8.3. When approved, the specified actions and activities to fulfill the Assessment requirements are documented, and activities specified are incorporated into the project plan at points (milestones) in the development and/or deployment preparation and execution phases, as determined through stakeholder input and consensus. .

3.8.3.1. Appropriate testing is conducted and results documented. Additional testing may be required to complete Phase III.

3.8.3.2. Phase I materials must be updated as part of the Phase II verification, in order to get the initiative plan and documentation reconciled for final Assessment review, approval, and sign off by the Certifying Authority (CA).

3.9. The A&A Plan, which now includes Phase I and Phase II, should be reviewed by WVOT's Chief Information Security Officer (CISO), with concurrent review and requests for additional information or enhancement leading to approval by any impacted stakeholders.

3.10. Authorization: Phase III

3.10.1. Authorization is the culmination of the A&A process. At this point the Assessment plan, the testing, and the results are submitted for final Authorization review.

3.10.2. A completed A&A binder (or Authorization package) is forwarded by the Assessment (team) leader to the CA, or a A&A Board (A&AB) if designated. This package includes:

3.10.2.1. The A&A Plan, updated from Phase II to reflect the findings of testing and other Assessment activities.

3.10.2.2. Actual Phase II details, testing results documentation, and any risk analysis documentation that includes final risk levels determined, and risk designated as residual risk, to be accepted and managed.

3.10.2.3. Proposed “go-live” date and any rollout planning/scheduling documentation, and

3.10.2.4. Signed recommendation of the Assessment (team) leader for approval to deploy.

3.11. The A&A binder (Authorization package) is reviewed by the CA. If satisfied that the A&A requirements are met, an Authorization statement of approval is issued by the CA. The CA, unless otherwise designated by the WVOT CIO, is the WVOT CIO.

3.12. The Authorization statement of approval, issued by the CA, permits deployment of the system, application or system software, or other technology.

3.13. Monitoring: Phase IV

3.13.1. Once a device, system, application and system software, or other technology is formally accredited, the life-cycle of the deployed technology must be monitored to ensure that all applicable standards are maintained.

3.13.1.1. Changes to devices, systems, application and system software, or other technologies must be documented and analyzed for security impact, with appropriate remediation of findings of adverse security impact.

3.13.1.2. Every 3 years, or when major changes occur in software and/or hardware (whichever occurs first), responsible parties will be required to update the A&A documentation, to gain re-authorization of the device, system, application and system software, or other technology.

3.14. Pre-existing deployments of devices, systems, application and system software, and other technology:

3.14.1. Devices, systems, application and system software, and other technology currently deployed must be identified, and are subject to a risk assessment review to assure that they do not pose unacceptable risk within the State of West Virginia technology environment. At the request of the CIO, or CISO, a A&A requirement may be imposed on any pre-existing technology.

4. POLICY SPECIFIC DEFINITIONS

4.1. Access– the ability to locate, gain entry to, and use a directory, file, or device on a computer system or over a network.

4.2. Assessment - an evaluation process assessing non-technical and technical security management, operations, and technical controls, policy, and requirements. Risk analysis along with vulnerability assessments produce documents that support management decisions.

4.3. Assessment and Authorization (A&A) – Validation process that ensures that the West Virginia Office of Technology validates the security readiness for devices, systems, software, and other technology prior to deployment of technology into a production status. This validation includes appropriate reviews and/or testing of configurations, hardening, functionality and compliance with specifications, regulations, standards and objectives for the generated deployment activities.

4.4. Chief Information Officer (CIO) - the person designated by the governor to lead the WV Office of Technology and oversee information technology practices and initiatives for the Executive Brand of WV State government, excluding the constitutional officers.

4.5. Chief Information Security Officer (CISO) - Person designated by the CIO to oversee information security practices and initiatives for the Executive Branch of WV State government, excluding the constitutional officers.

4.6. Information Resources – All information assets, in all known formats.

4.7. Information Security – measures, procedures, and controls that provide an acceptable degree of safety for information resources, protecting them from accidental or intentional disclosure, modification, or destruction.

4.8. Office of Primary Responsibility (OPR) - The primary section within WVOT that takes the lead on a specific policy or procedure. Usually the WVOT service provider/owner that the policy is related to or governs.

4.9. Procedure – A defined series or sequence of steps followed in a definite regular order ensuring the consistent and repetitive approach to actions.

4.10. Risk Analysis – The evaluation of system assets and their vulnerabilities to threats in order to identify what safeguards are needed.

4.11. Threat – Includes any person, condition, or circumstance that endangers the security of information or information systems in the context of information security.

4.12. West Virginia Office of Technology (WVOT) - The division of the Department of Administration established by WV Code § 5A-6-4a, et. seq., which is led by the State's CIO and designated to acquire, operate, and maintain the State's technology infrastructure. The WVOT is responsible for evaluating equipment and services, and reviewing information technology contracts.

5. RELEVANT MATERIALS AND DOCUMENTS

5.1. 45 Code of Federal Regulations (CFR) §§ 164.308-316

5.2. Freedom of Information Act

5.3. Gramm-Leach Bliley Act (GLBA)

5.4. Health Insurance Portability and Accountability Privacy Rule

5.5. NIST SP 800-14 and NIST SP 800-53

5.6. State Health Privacy Laws

5.7. WV Code § 5A-6-4a

5.8. WV Executive Order No. 7-03

5.9. WVOT Policies Issued by the Chief Information Officer (CIO), https://sites.google.com/wv.gov/othub/policy-governance/ot-policies

5.10. Appendix A - Sample Assessment and Authorization Plan Outline

5.11. Appendix B - Assessment and Authorization Statement Examples

Appendix A - Sample Assessment and Authorization Plan Outline

Below is a sample outline for common parts of a Assessment and Authorization Plan:

PHASE I

System Information

System Requirements

System Justification

Responsibilities

Time Frame

Known Issues or Concerns

Technical Testing Plan

PHASE II

Relevant Security Controls

Test Results

Re-Testing and Results

Discussion Notes and Documentation about Known Risks

Proposed Mitigation & Recommendations

Assessment Statement

PHASE III

Documentation of Acceptable Risks

Stipulations and Requirements

Authorization Statement

Appendix B - Assessment and Authorization Statement Examples

Assessment and Authorization Statements should be signed by the appropriate authority.

Security Assessment Statement

The following recommendations must be considered before the Unity Communication and Messaging System is certified:

1. It is the recommendation of the Security Group that the Agency complete Task X before going live.

2. Vulnerability scans should be conducted every X years/months/days.

3. Other concerns.

Risk Authorization Statement

During the Assessment Process, the following vulnerabilities and/or risks were discovered.

Vulnerability #1

Description of issue.

Risk Level:

Vulnerability #2

Description of issue.

Risk Level:

At the time of this A&A Plan, the residual risks associated with the continued operation of the Unity Connection Cluster are acceptable and the system is granted approval to operate until FY20xx (3 years) without being recertified